

LAB 7:Q

Question 1

Due to the low packet volume in the PCAP file, I performed a manual analysis and identified an outlier packet with an unusual size relative to the rest of the traffic.

26	12.016124	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=13/3328, ttl=64 (request in 25)
27	13.017863	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=14/3584, ttl=63 (reply in 28)
28	13.017885	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=14/3584, ttl=64 (request in 27)
29	14.019271	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=15/3840, ttl=63 (reply in 30)
30	14.019288	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=15/3840, ttl=64 (request in 29)
31	15.020536	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=16/4096, ttl=63 (reply in 32)
32	15.020554	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=16/4096, ttl=64 (request in 31)
33	16.022411	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=17/4352, ttl=63 (reply in 34)
34	16.022431	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=17/4352, ttl=64 (request in 33)
35	17.023677	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=18/4608, ttl=63 (reply in 36)
36	17.023696	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=18/4608, ttl=64 (request in 35)
37	18.025625	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=19/4864, ttl=63 (reply in 39)
38	18.025681	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=19/4864, ttl=63 (reply in 39)
39	18.025699	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=19/4864, ttl=64 (request in 38)
40	19.026884	172.24.20.31	171.64.20.62	ICMP	98 Echo (ping) request	id=0x7a93, seq=20/5120, ttl=63 (reply in 41)
41	19.026985	171.64.20.62	172.24.20.31	ICMP	98 Echo (ping) reply	id=0x7a93, seq=20/5120, ttl=64 (request in 40)

Frame 37: 70 bytes on wire (560 bits), 70 bytes captured (560 bits)	0000	00 0c 29 58 4f 6e b4 0c 25 ea 40 10 00 00 45 00	)XOn .. %..E
Ethernet II, Src: PaloAltoNetw ea:40:10 (b4:0c:25:ea:40:10), Dst: VMware 58:4f:6e (00:0c:29:58:4f:6e)	0010	00 38 02 2d 00 00 01 f9 e2 ac 18 14 1f ab 40	8 0
Internet Protocol Version 4, Src: 172.24.20.31, Dst: 171.64.20.62	0020	14 3e 00 00 1c a8 00 01 00 00 55 31 56 44 56 45	> U1VDVE
Internet Control Message Protocol	0030	59 79 4d 44 49 7a 65 32 46 70 50 32 6c 7a 50 32	YyMDIre2 FpX2IzX2
Type: 0 (Echo (ping) reply)	0040	4e 70 62 32 70 39	Nvb2x9
Code: 0			
Checksum: 0x1ca8 [correct]			
[Checksum Status: Good]			
Identifier (BE): 1 (0x0001)			
Identifier (LE): 256 (0x0100)			
Sequence Number (BE): 0 (0x0000)			
Sequence Number (LE): 0 (0x0000)			
Data (28 bytes)			
Data: 55315644564559794d44497a6532467058326c7a58324e7662327839			
[Length: 28]			

After identifying Base64 encoding within the file data, I used the open-source tool CyberChef to decode it.

The screenshot shows the CyberChef web interface. On the left, the 'Recipe' panel is configured with 'From Base64' and 'Alphabet A-Za-z0-9+/' selected. The 'Input' panel contains a long Base64 string. The 'Output' panel displays the decoded result: `SUCTF2023{ai_is_cool}`.

Answer : SUCTF2023{ai_is_cool}

Question 2

Because the ICMP packets share identical file sizes, they can be filtered out of the dataset. Consequently, the analysis will focus exclusively on TCP traffic.

No.	Time	Source	Destination	Protocol	Length	Info
219	86.639769	171.64.20.62	172.24.20.31	FTP	150	Response: 150 Opening BINARY mode data connection for global_thermonuclear_war.gamerules.txt
216	86.640792	171.64.20.62	172.24.20.31	FTP-DA	95	FTP Data: 29 bytes (PASV) (RETR global_thermonuclear_war.gamerules.txt)
217	86.640816	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [FIN, ACK] Seq=30 Ack=1 Win=65280 Len=0 TSval=3516241511 TSecr=2741347213
218	86.640912	172.24.20.31	171.64.20.62	ICP	76	ICP: 500 ACK=37697 Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347215 TSecr=3516241509 SLE=30 SRE=31
219	86.640916	172.24.20.31	171.64.20.62	ICP	66	42414 → 37697 [ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347215 TSecr=3516241511
220	86.642257	172.24.20.31	171.64.20.62	ICP	66	42414 → 37697 [FIN, ACK] Seq=1 Ack=31 Win=65536 Len=0 TSval=2741347217 TSecr=3516241511
221	86.642264	171.64.20.62	172.24.20.31	TCP	66	37697 → 42414 [ACK] Seq=31 Ack=2 Win=65280 Len=0 TSval=3516241513 TSecr=2741347217
222	86.602483	172.24.20.31	171.64.20.62	TCP	66	59170 → 21 [ACK] Seq=146 Ack=329 Win=65536 Len=0 TSval=2741347257 TSecr=3516241511
223	86.602494	171.64.20.62	172.24.20.31	FTP	90	Response: 226 Transfer complete.
224	86.603519	172.24.20.31	171.64.20.62	TCP	66	59170 → 21 [ACK] Seq=146 Ack=352 Win=65536 Len=0 TSval=2741347258 TSecr=3516241553
225	86.603758	172.24.20.31	171.64.20.62	FTP	111	Request: MDTM global_thermonuclear_war.gamerules.txt
226	86.603918	171.64.20.62	172.24.20.31	FTP	86	Response: 213 20230924192313
227	86.126336	172.24.20.31	171.64.20.62	TCP	66	59170 → 21 [ACK] Seq=191 Ack=372 Win=65536 Len=0 TSval=2741347381 TSecr=3516241555
234	89.117001	172.24.20.31	171.64.20.62	FTP	72	Request: QUIT
235	89.117125	171.64.20.62	172.24.20.31	FTP	78	Response: 221 Logout
236	89.117471	172.24.20.31	171.64.20.62	TCP	66	59170 → 21 [ACK] Seq=197 Ack=384 Win=65536 Len=0 TSval=2741350292 TSecr=3516244588
237	89.117798	172.24.20.31	171.64.20.62	TCP	66	59170 → 21 [FIN, ACK] Seq=197 Ack=384 Win=65536 Len=0 TSval=2741350292 TSecr=3516244588
238	89.117912	171.64.20.62	172.24.20.31	TCP	66	21 → 59170 [FIN, ACK] Seq=384 Ack=198 Win=65280 Len=0 TSval=3516244589 TSecr=2741350292
<pre> Frame 216: 95 bytes on wire (760 bits), 95 bytes captured (760 bits) on interface 0 Ethernet II, Src: VMware_58:4f:de (00:0c:29:58:4f:de), Dst: PaloAltoNetw_ea:40:10 (b4:0c:25:ea:40:10) Internet Protocol Version 4, Src: 171.64.20.62, Dst: 172.24.20.31 Transmission Control Protocol, Src Port: 37697, Dst Port: 42414, Seq: 1, Ack: 1, Len: 29 FTP Data (29 bytes data) Setup frame: 216 [Setup method: PASV] [Command: RETR global_thermonuclear_war.gamerules.txt] [Current frame: 213] [Current working directory:] [Line-based text data (1 lines)] https://tinyurl.com/yr5zprz4n </pre>						

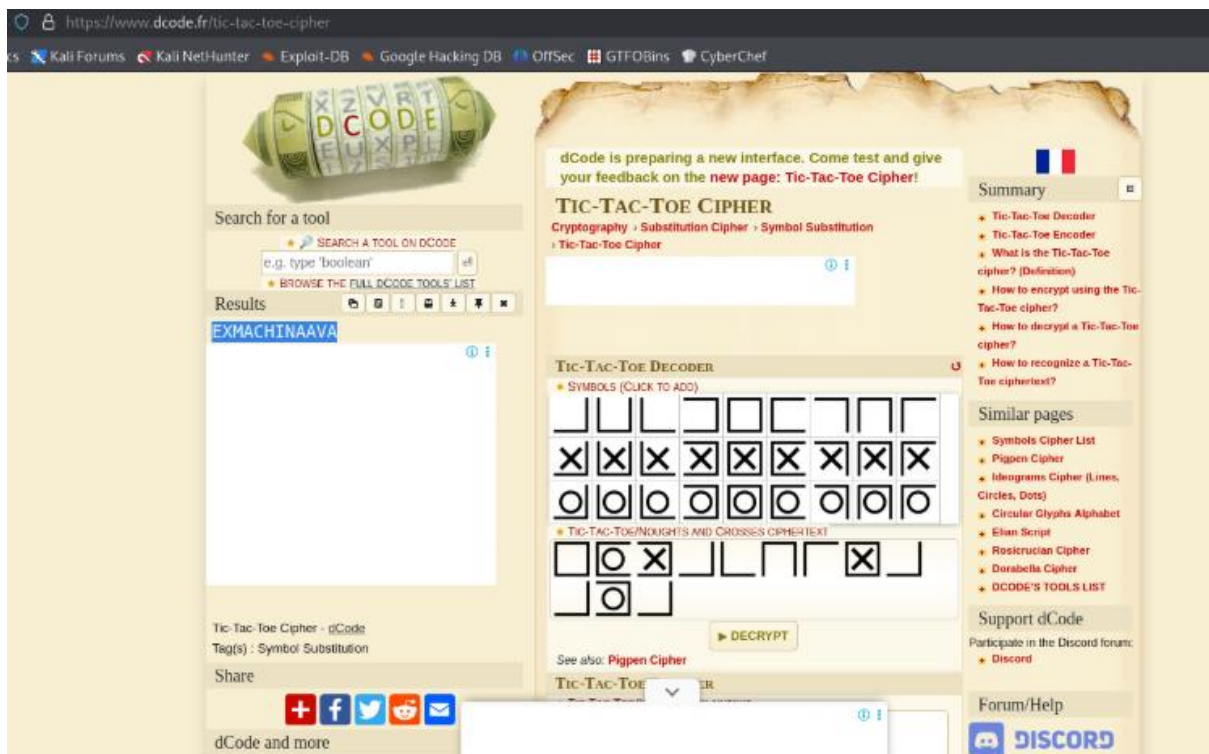
Analysis of the output reveals a successfully transferred file named global_thermonuclear_war.gamerules.txt. Navigating to the hyperlink found within this text file leads to a Google Doc named 'Club Tux,' which contains images embedded with anomalous symbols.

https://docs.google.com/document/d/1C_Poetm93MxbB0pZxbBB0z0b1881x_LxRlthacLYbuc/edit?pli=1&tab=t.0

forums Kali NetHunter Exploit-DB Google Hacking DB OffSec GTF0Bins CyberChef

⊠⊙⊗⊐⊑⊒⊓⊔⊕⊖⊗⊘⊙⊚

The TCP stream reveals a conversation referencing a Tic-Tac-Toe cipher. Cross-referencing this cryptosystem allowed for the translation of the symbols found in the document, successfully decoding the final plaintext solution.



Answer: EXMACHINAAVA

Question 3

Interpret an Nmap Output

PORT STATE SERVICE VERSION 21/tcp open 6p vs6pd 2.3.4 22/tcp open ssh OpenSSH 5.3p1 80/tcp open hBp Apache 2.2.8 139/tcp open netbios-ssn 445/tcp open microsofts Windows 7 Professional 7601 Service Pack 1

Questions:

1. What can an attacker do with each port?
2. What vulnerabilities are likely present based on the version?

Port 21/tcp – FTP: Hosts file transfer capabilities. Services running legacy or unpatched versions can be leveraged by attackers to exploit known vulnerabilities, establish backdoors, or gain unauthorized access to stored repository data.

Port 22/tcp – SSH (OpenSSH 5.3p1): Provides secure, encrypted remote access. However, it remains a frequent target for credential stuffing and brute-force attacks aimed at guessing passwords. Compromising weak credentials grants direct shell access, while older versions may harbor unpatched flaws that permit persistent network access.

Port 80/tcp – HTTP (Apache 2.2.8): Exposes a web server running a legacy version of Apache. This application layer is routinely probed for software misconfigurations, injection flaws, and web application vulnerabilities that could facilitate remote code execution (RCE) or a system foothold.

Port 139/tcp – NetBIOS-SSN: Supports legacy Windows networking and resource sharing. Attackers utilize this service for network enumeration to harvest host details, usernames, and shared resources without authentication, generating the intelligence necessary to map out subsequent attack vectors.

Port 445/tcp – SMB (Microsoft-DS): Facilitates Windows-native file and printer sharing. Beyond standard user enumeration and password-spraying risks, SMB services historically present severe vulnerabilities that allow unauthenticated remote code execution, threatening complete system compromise and lateral movement.

3. Which one is the highest risk and why?

Port 21 presents the highest risk due to an unauthenticated, low-complexity remote exploit vector that results in a complete compromise of system confidentiality, integrity, and availability. The presence of a verified backdoor elevates the severity to a critical threshold, carrying a CVSSv3 score of 9.8

4. What attack path can be built from this?

Phase 1: Initial Foothill via Exploit: The attacker targets Port 21 (FTP) to exploit the known vsFTPD 2.3.4 backdoor, establishing immediate, unauthenticated remote shell access with high reliability.

Phase 2: Web Application Assessment: Concurrently, the attacker probes Port 80 (HTTP) to identify web application vulnerabilities—such as insecure file uploads or command injection—to secure secondary entry points.

Phase 3: Local Enumeration: Upon obtaining an initial shell, the attacker conducts local enumeration to discover active user accounts, running internal services, and local network configurations to map out privilege escalation vectors.

Phase 4: Lateral Information Gathering: The attacker leverages the local foothold to target internal NetBIOS and SMB services (Ports 139 and 445), enumerating misconfigured network shares to extract usernames and sensitive files.

Phase 5: Credential Stuffing & Persistence: Utilizing harvested credentials, the attacker targets Port 22 (SSH) via brute-force or credential-reuse techniques to secure stable, authenticated persistence across the environment.

Phase 6: Privilege Escalation & Lateral Movement: Finally, the attacker consolidates control by escalating privileges to root or administrator, establishing persistent access mechanisms, and initiating lateral movement across the internal subnetwork.

5. What should be the remediation?

FTP (Port 21): Upgrade or remove vsftpd 2.3.4 to remediate a critical backdoor vulnerability. Replace with SFTP, disable anonymous login, and restrict network access via firewall rules.

SSH (Port 22): Harden OpenSSH 5.3p1 by upgrading to the latest version, disabling password authentication in favor of SSH keys, blocking root logins, and deploying fail2ban for rate limiting.

HTTP (Port 80): Remediate legacy Apache 2.2.8 by upgrading to a supported version. Suppress banner details, remove unnecessary modules, integrate a WAF, and fix application-layer vulnerabilities.

NetBIOS (Port 139): Mitigate enumeration risks by disabling NetBIOS where possible, firewalling-blocking external access, preventing null sessions, and limiting shares to isolated segments.

SMB (Port 445): Mitigate remote exploit risks by completely disabling SMBv1, enforcing the latest security updates, removing unnecessary shares, and restricting access to internal networks.

Question 1: TTL=64

A Time-to-Live (TTL) value of 64 typically indicates that the packet originated from a Linux or Unix-based operating system. While named "Time-to-Live," the field functions as a hop counter within the IP header, decrementing by one at each routing hop to prevent infinite routing loops. Network analysts utilize the remaining TTL value for OS fingerprinting and network distance estimation, though it is not a definitive indicator due to potential packet manipulation or custom configurations.

Question 2: TTL=255

A TTL value of 255 indicates a packet initialized with the maximum possible hop limit, a configuration standard for network infrastructure devices such as routers and switches. Because the value decrements at each routing hop, observing a remaining TTL close to 255 implies the source host is either an infrastructure device or located in close proximity within the local network. This maximum value ensures packet delivery across vast topologies and supports security validations in specific network protocols.

Question 3: TTL=128

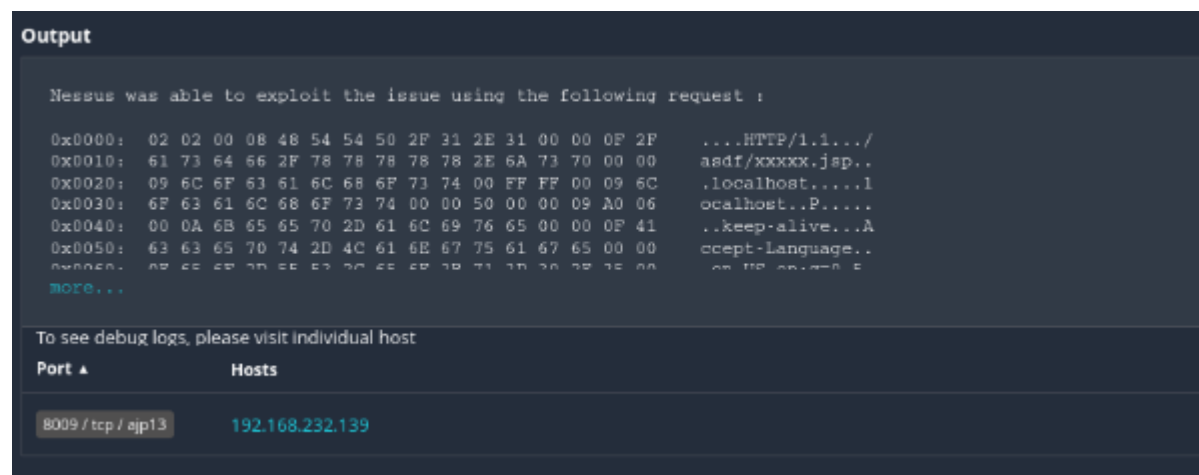
A TTL value of 128 strongly suggests the packet was generated by a Windows-based operating system, which uses 128 as its default initial hop limit. Like other TTL configurations, this field decrements by one at each layer-3 hop to mitigate network congestion and routing loops. Tracking the difference between the default and received TTL allows analysts to calculate the network hop count, serving as a valuable tool for passive OS fingerprinting and network analysis.

Question 4:

Identify the OS (OS Fingerprinting) – TTL

Question 5: Nessus Scan Analysis

Import the Network_Scan.nessus file into Nessus and analyze the results. Focus exclusively on the Critical or High-severity vulnerabilities associated with the exploit named "Ghostcat."



The screenshot displays the 'Output' section of a Nessus scan. It shows a successful exploit for the 'Ghostcat' vulnerability. The exploit request is detailed in hexadecimal and ASCII format. Below the request, there is a table with columns 'Port' and 'Hosts'. The table shows that the exploit was successful on port 8009/tcp of host 192.168.232.139.

```
Output

Nessus was able to exploit the issue using the following request :

0x0000: 02 02 00 08 48 54 54 50 2F 31 2E 31 00 00 0F 2F    ...HTTP/1.1.../
0x0010: 61 73 64 66 2F 78 78 78 78 78 2E 6A 73 70 00 00    asdf/xxxxx.jsp..
0x0020: 09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C    .localhost.....l
0x0030: 6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06    ocalhost..P.....
0x0040: 00 0A 6B 65 65 70 2D 61 6C 69 76 65 00 00 0F 41    ..keep-alive...A
0x0050: 63 63 65 70 74 2D 4C 61 6E 67 75 61 67 65 00 00    ccept-language..
0x0060: 65 65 65 70 65 63 70 65 65 78 71 7D 70 75 75 00    or HTTP/1.1...F
MORE...

To see debug logs, please visit individual host

Port ▲      Hosts
8009 / tcp / ajp13    192.168.232.139
```

1. What is the affected Port number

8009

2. What is the Affected protocol

ajp

3. What is the CVSS Score of vulnerability found

98

Risk Information

Vulnerability Priority Rating (VPR): 9.6

Risk Factor: High

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS v3.0 Temporal Vector: CVSS:3.0/E:P/RL:O/RC:C

CVSS v3.0 Temporal Score: 8.8

CVSS v2.0 Base Score: 7.5

CVSS v2.0 Temporal Score: 5.9

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P

CVSS v2.0 Temporal Vector: CVSS2#E:POC/RL:OF/RC:C

4. Can you find any exploit related to this vulnerability?

CVE-2020-1938

CVE-2020-1938 Detail

Description

When using the Apache JServ Protocol (AJP), care must be taken when trusting incoming connections to Apache Tomcat. Tomcat treats AJP connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited in ways that may be surprising. In Apache Tomcat 9.0.0.M1 to 9.0.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99, Tomcat shipped with an AJP Connector enabled by default that listened on all configured IP addresses. It was expected (and recommended in the security guide) that this Connector would be disabled if not required. This vulnerability report identified a mechanism that allowed: - returning arbitrary files from anywhere in the web application - processing any file in the web application as a JSP Further, if the web application allowed file upload and stored those files within the web application (or the attacker was able to control the content of the web application by some other means) then this, along with the ability to process a file as a JSP, made remote code execution possible. It is important to note that mitigation is only required if an AJP port is accessible to untrusted users. Users wishing to take a defence-in-depth approach and block the vector that permits returning arbitrary files and execution as JSP may upgrade to Apache Tomcat 9.0.31, 8.5.51 or 7.0.100 or later. A number of changes were made to the default AJP Connector configuration in 9.0.31 to harden the default configuration. It is likely that users upgrading to 9.0.31, 8.5.51 or 7.0.100 or later will need to make small changes to their configurations.

QUICK INFO

CVE Dictionary Entry:

[CVE-2020-1938](#)

NVD Published Date:

02/24/2020

NVD Last Modified:

10/27/2025

Source:

Apache Software Foundation

5. Find CVE for this vulnerability.

Vulnerability Information

CPE: cpe:/a:apache:tomcat

Exploit Available: true

Exploit Ease: Exploits are available

Patch Pub Date: March 1, 2020

Vulnerability Pub Date: March 1, 2020

Exploited by Nessus: true

Reference Information

CVE: [CVE-2020-1938](#), [CVE-2020-1745](#)

CVE: CVE-2020-1938, CVE-2020-1745